2026 年第十四届全国大学生数字媒体科技作品及创意竞赛 · 自主选题类 · 移动与网络应用开发类

PrivacyTrace

移动应用静态隐私证据与政策声明对照

把一条静态隐私线索和一段政策原句，落到各自可复核的位置上；不判定合规、安全，也不判定是否真的采集。

作品汇报 · 评审匿名版（不含校名、成员姓名与账号） · 2026-10-23 · v0.1
本稿数字截至 2026-10-23；前端迁移与验收仍在收口，标注「进行中」的条目以随包最新记录为准。

Outline

汇报结构

1. 作品定位：把证据摊开，不下判决 — *3 min*
2. 主要创新：四项有证据的设计 — *5 min*
3. 技术与创作方法：工作流与工程管理 — *5 min*
4. 成果：受控评测、真实运行与界面 — *5 min*
5. 原创贡献、边界与后续 — *3 min*

口径提醒：工程测试通过 ≠ 受控评测完成 ≠ 真实 App 评测。本稿把三类证据分开陈述，不互相替代，也不把「没做」写成「没通过」。

1

SECTION ONE

把证据摊开，把判断留给用户

定位 · 用户 · 三条明确不做的事

§1 · 定位

它是什么，不是什么

摘要. *PrivacyTrace 读取 Android 安装包里能静态看到的隐私线索，与隐私政策原文逐条对照；每条结论都能回到代码位置与政策原句。它只回答「代码里有没有这个线索、政策里有没有这句话」，不回答「应用是否合规、是否安全、是否真的采集」。*

给谁

普通 Android 用户：不要求会读代码，也不要求懂法务文本。目标是把专业级、可多源追溯的隐私证据，变成能自己复核的隐私体检。

分析范围

定位、标识、联系人、相机、麦克风、文件与媒体（含截屏）。APK 支持单包，也支持 base + 全部 splits。

明确不做

- ☑ 不判定合规、安全或违法
- ☑ 不推断是否向第三方传输
- ☑ 不做动态抓包，不自动理解政策

形态：Android 客户端 + Web 工作台 + 隔离扫描 API + 离线只读回放。分析只在本机或受控内网运行，当前没有公网实例。

§1 · 可复核性

一条结论，两次点击走到原点



Figure 1： *报告的三层结构与两次下钻。目标不是让人相信结论，而是让人可以自己走一遍、自己验算。*

偏移可自行切算
政策原句的 `[start, end)` 落在全文快照上，切出来的必须是同一句。

未证实的保留为 UNKNOWN
目的、接收方、跨境、期限无法从静态材料推出，就不写。

合成与真实分开标识
演示数据是人工构造样本；真实样本另附运行记录，报告里明确区分。

2

SECTION TWO

四项设计，都有可指认的证据

双向证据链 · 克制判定 · 评测协议 · 隔离回放

§2 · 创新一

双向证据链：结论必须能回到两侧原点

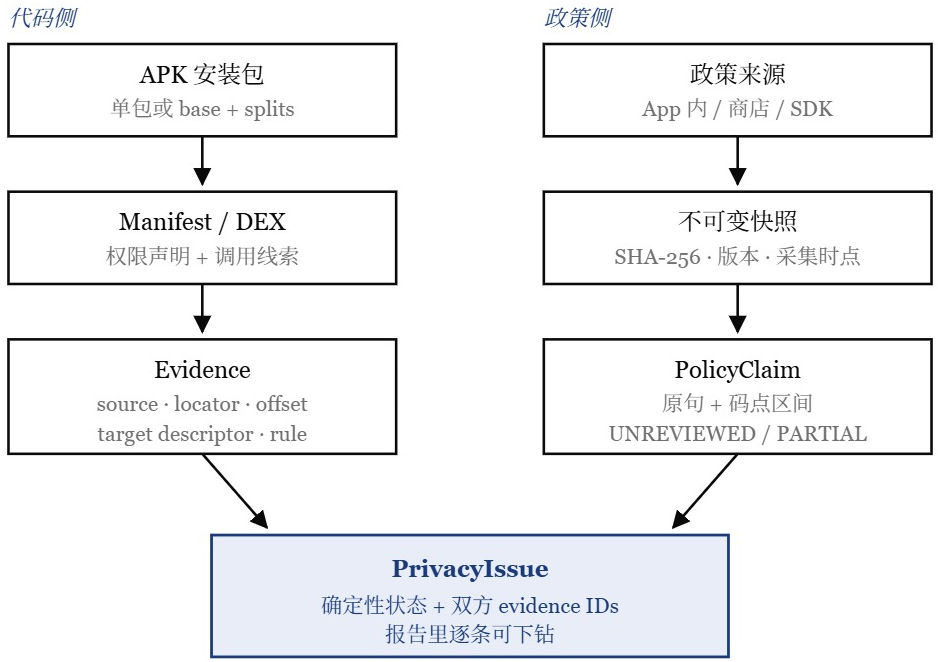


Figure 2： *代码侧与政策侧各自独立取证，在 PrivacyIssue 汇合；任何一侧缺失，结论只能是「证据不足」。*

真实样本：GKD v1.12.1（2026-10-09 记录）

```
ev-887b01d4… · classes.dex
Lr2;->p · offset_bytes = 2
→ AccessibilityService.takeScreenshot

policy-sentence-1 · [363, 423)
条件：「仅调试」

判定：INSUFFICIENT_EVIDENCE
```

- ☑ 两侧都能自己走：文件 / 方法 / 偏移 / 目标 API，政策全文 / 码点区间。
- ☑ 区间按 Unicode 码点、半开区间；切出来的必须与原句一致。
- ☑ 无法证明的参数保持 UNKNOWN，不用推断补全。

§2 · 创新二

克制判定：把「没有证据」写成一种结论

层级	我们写下	我们不会写
权限	能力声明 CAPABILITY_ONLY：「申请了读取相册的能力」	「偷看了相册」
调用	静态线索 STATIC_POTENTIAL：「出现一处相关调用线索」	「已采集 / 已上传」
政策	声明状态（UNREVIEWED / PARTIAL）与原文区间	「政策合规」
对照	六类状态之一；证据不够就是 INSUFFICIENT_EVIDENCE	「违法 / 不安全」
未知	保留 UNKNOWN：目的、接收方、跨境、期限	推测出一个答案

> *「未命中规则不代表没有隐私行为。」 — 项目能力边界*

六类状态只对照「数据类型是否被声明」。「具体类型已声明」不代表目的、接收方、传输或时间范围一致，更不是合法性判断。

§2 · 创新三

可复现的评测协议：先冻结真值，再跑算法

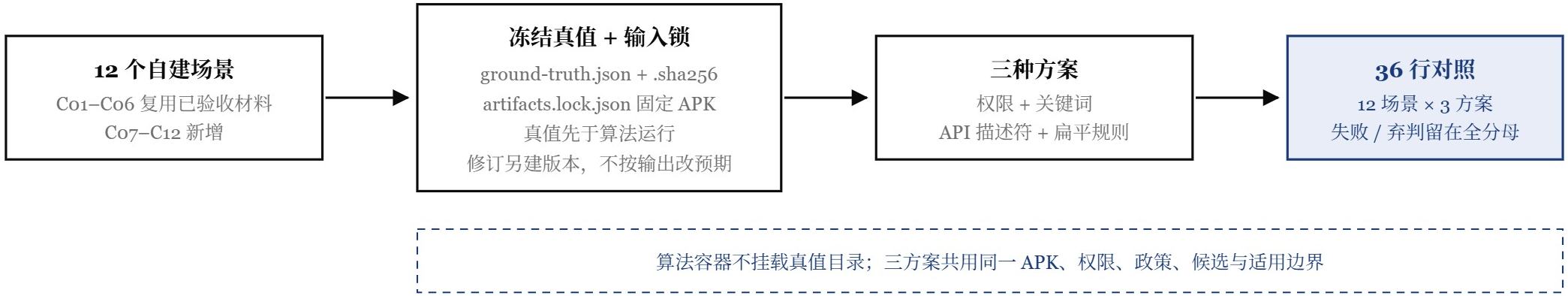


Figure 3： *评测协议。先冻结真值与输入，再让三种方案跑同一份材料；本系统使用既有规则引擎，不做事后调参。*

12
受控场景

3
对照方案

36
对照行

P / R / F1 按协议为 N/A：没有二元「实际采集 / 合法性」真值，就不在事后设立正类。
指标只报状态一致数、失败与弃判。

§2 · 创新四

隔离执行与断网回放：限制写在参数里

扫描容器：未知 APK 只在受限环境里解析

```
user 65534 (非 root)
network none
read-only rootfs
cap-drop ALL
1 CPU · 1 GiB · PID 32
```

扫描退出后清理运行目录，并用 `docker inspect` 复核容器参数；宿主机只负责调用，不在宿主机解析未知 APK。

离线回放：打开前先验包

- ☑ 包内 viewer 启动前校验文件集合与 SHA-256；新增、遗漏、篡改即拒绝启动。
- ☑ 不重跑扫描、不连网、不需要 Docker 或额外服务。
- ☑ 24 个成员 / 3,056,905 B；结果绑定交付 SHA，可在断网环境复现。

回放不是重扫：打开包只还原已保存的报告与证据，不调用分析链路。

隔离参数是执行约束，不是安全认证；回放包是内部限定验收，不含公开分发授权。两者都不能替代对真实应用的评测。

§3 · 工作流

从材料到报告：六步，每一步都有状态

1. **材料**：APK（单包 / base + splits）与政策来源；来源可以是自动发现、网页辅助或手工导入。
2. **候选**：政策候选默认由人工准备；可选模型候选一律标记 `UNREVIEWED`，不参与最终裁决。
3. **确认**：用户确认包集合、上传范围与政策候选；取消与返回都不改变草稿原状态。
4. **扫描**：仅未知 APK 进入隔离 Worker；本机或部署模式使用同一套扫描参数。
5. **对照**：确定性规则输出六类状态；事实、声明、推断分开存放。
6. **报告**：概览 → 按来源对照 → 证据下钻；可导出、可离线回放。

四种证据，分开存放

层级	能证明	不能证明
工程测试	代码按预期运行	APK 分析有效性
受控评测	自建场景下的名义对齐	真实 App 表现
真实样本	个案链路跑通	全局精度 / 召回
正式提交	系统受理	工程验收

这张表决定了汇报里每个数字的措辞：不把「测试通过」说成「评测通过」，也不把「上传成功」说成「提交成功」。

六步的状态都以页面文字呈现；颜色只是冗余编码，不从颜色推断结论。

§3 · 工程管理

把「可复现」做成流程，而不是口号

机制	做法	结果（2026-10-23 快照）
交付治理	TheMasterplan v5.0.0 固定 SHA；Issue / 子票 / PR；单一交付责任人；子票未完成不在父票勾完成。	采纳记录与 PR 历史可查；没有「口头完成」。
唯一验证入口	`scripts/check.sh` 与 CI 同名工作流；Python / Web 测试、Ruff、契约导出、构建一次跑完。	后端 1640 passed / 179 skipped；Web 65 passed；Ruff、契约、构建通过。
证据绑定	真值先行冻结；输入锁；交付 SHA；离线包 SHA-256；引用数字必须带时点与版本。	复查时能回到同一版材料，而不是「最新 main」。
验收矩阵	H（成功组合）/ N（负向）/ F（故障恢复）三类用例；另有 8 项匿名化自查门禁。	H01–H11 通过；H12 失败并如实记录（见成果页）。
材料创作	截图取自真实运行；影片取真实操作 + 分镜 + 原创配乐；数字全部可复算，缺口直接写在材料里。	不使用概念图，不虚构比例，不把规划写成已达成。

CI 数字来自 2026-10-22 的 Check 运行（`e52cc71`）；跳过项包含需真实 Docker / PostgreSQL / Redis 与受控构建显式开启的用例，不计入通过数。

§4 · 成果

十二个受控场景：状态一致 12/12

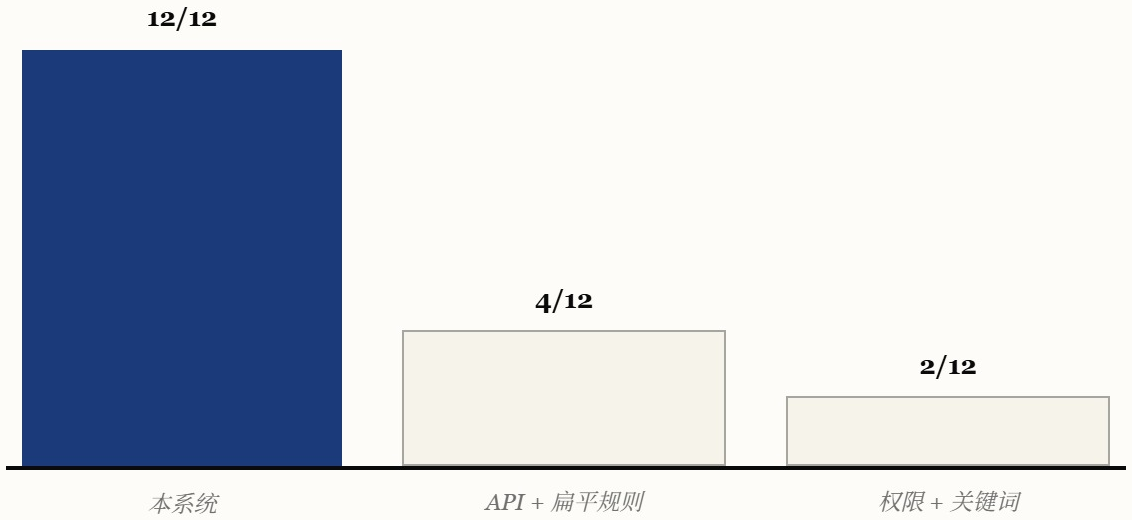


Figure 4： *三方案在同一份材料上的状态一致数（36 行对照）。蓝色为本系统；灰色为对照方案。*

本系统 *对照方案*

口径	数值 / 说明
场景	12 个（C01–C12）
对照	3 方案 × 12 场景 = 36 行
状态一致	本系统 **12/12**；API+扁平 4/12；权限+关键词 2/12
失败 / 弃判	如实保留在全分母
P / R / F1	N/A（无二元采集真值）

不能从这张表推出：真实 App 的检测准确率、实际采集或传输行为、合法性结论、商业应用泛化性能。

原六场景评测（2026-10-12）为 2/6、3/6、6/6，保留原时点与原 SHA，不用新结果替换历史记录；本页引用的是十二场景扩展版。

§4 · 成果与反证

用户、设备与交付：有成绩，也有没通过的

理解测试（6 人，探索性）

- ☑ 主观可读性均值 **4.00**（对照材料 2.33）
- ☑ **6/6** 认为更方便找到依据
- ☑ 定位任务 **12/12** 成功
- ☑ Co5 冲突场景 **4/4** 读成「不涉及定位」→ 报告层级待改

样本小、非随机、顺序不平衡；是探索性记录，不作产品效果结论。

Android 端到端矩阵

`H01–H11 PASSED` `H12 FAILED`

- ☑ H12：splits × 手机模型 × 自托管，报告缺模型原句与码点下钻，复现两次
- ☑ 仅 x86_64 / Android 15 竖屏；真机与 API 36 未覆盖
- ☑ #171 改界面后，客户端面未复验

真实样本与交付

- ☑ GKD v1.12.1：两次独立隔离运行语义一致；6 证据 / 3 行为 / 2 声明 / 3 判定，均为 `INSUFFICIENT_EVIDENCE`
- ☑ 评审片：120.000 s / 1080p / 30 fps / 无旁白
- ☑ 离线回放包：24 成员 / 3,056,905 B

未通过项不写成通过：H12 需要独立补跑窗口；真实 App 全局精度与召回仍未做，动态分析暂缓。

§4 · 真实运行界面

四步工作台：材料、候选、进度、报告

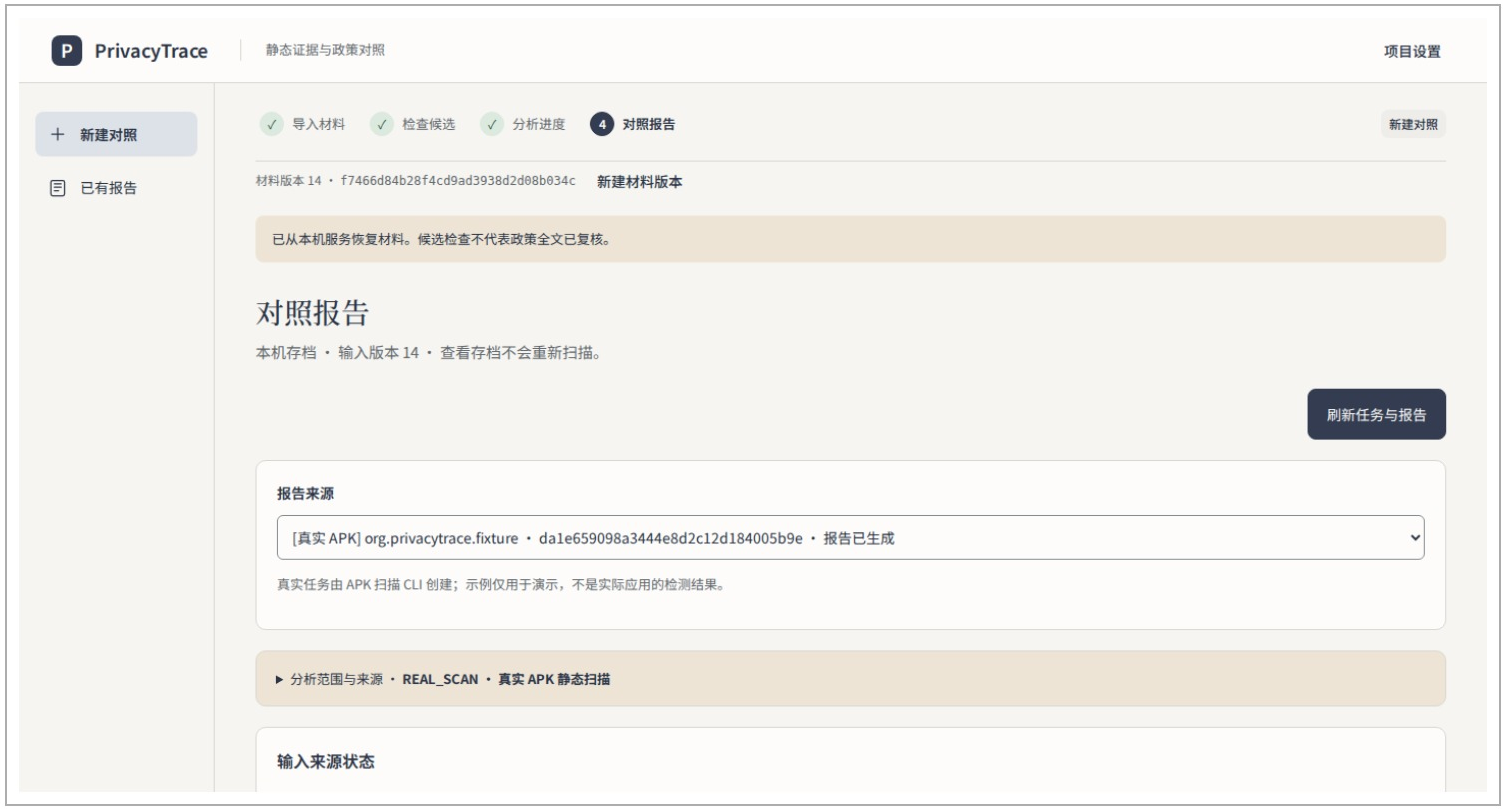


Figure 5： *报告页。报告来源、输入来源状态与核验范围在同一屏；失败来源被保留，政策状态以文字写明（未复核 / 部分提取 / 附件未检查）。*

- ☑ 四步固定流程：导入材料 → 检查候选 → 分析进度 → 对照报告。
- ☑ 报告不是一张「总分」：先给出来源与完整度，再给逐条对照。
- ☑ 「本机存档 · 查看不会重新扫描」写在标题下，避免把回放当成新分析。

截图取自 2026-10-22 候选包的真实运行。前端视觉基线仍在迁移，最终界面可能与此不同；本稿不把开发版界面宣称为最终视觉。

§4 · 证据下钻与移动端

下钻到字节码与码点；同一份报告在手机上可读



Figure 6: *「相机 · 证据不足」证据卡：权限配置只证明能力声明；候选条款标 `UNREVIEWED / PARTIAL`，原句位置 `[10, 24)` 按 Unicode 码点计数。*

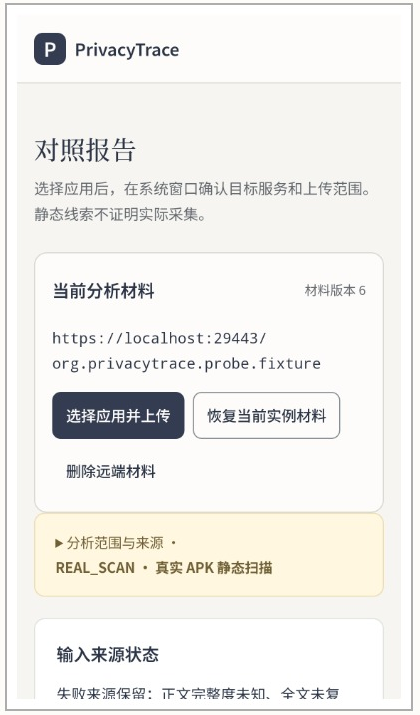


Figure 7: *Android 客户端复用同一任务与报告；静态线索不证明实际采集的提示固定在标题下。*

移动端主流程已合入；删除入口在「服务与存储设置」sheet，报告与证据面板共用 Web 端同一契约。

§5 · 原创贡献与披露

团队做了什么，AI 做了什么，边界在哪里

团队原创

- ☑ 定位、边界与数据契约
- ☑ 规则引擎与一致性判定
- ☑ 受控场景、冻结真值与评测协议
- ☑ 隔离执行与离线回放
- ☑ 客户端、界面与交付治理
- ☑ 材料、影片与验收记录

AI 使用（如实披露）

Gemini：文档起草与修订；**Codex**：实现与验证；**DeepSeek Harness**：材料与分镜；**Claude / WorkBuddy**：文案与材料整理。

AI 不参与最终事实裁决；生成内容先过机器校验，再人工审阅；不给出未经复算的比例；参赛材料按要求逐项披露。

第三方与边界

Vue 3 / Vite（MIT）、FastAPI / Pydantic（MIT）、Uvicorn（BSD-3）、Androguard 4.1.3（Apache-2.0）。

项目源码许可待团队最终决定；不宣称「100% 独立完成」，也不把 AI 参与描述为零。

成员 A/B/C… 为匿名评审表述；真实分工、AI 工具型号与人工修改范围见申报材料与随包披露文档。

结论 · 证据索引

把证据摊开，比下结论更难

1 · 定位成立

对照工具，不是合规判决器。三条「不做」写进产品与材料，也写进每一句措辞。

2 · 创新可指认

双向证据链、克制判定、可复现评测、隔离回放；四项都有文件、参数与数字可查。

3 · 仍在收口

H12 未通过、前端在迁移、真实 App 评测未做；不把未完成写成完成，是这稿的底线。

[1] 受控评测报告与复算脚本 *（随包 05_补充成果材料/）*

[2] 验收矩阵与 H12 缺口记录 *（随包 05_补充成果材料/）*

[3] 理解测试公开摘要 *（探索性，6 人）*

[4] 离线回放包与校验清单 *（41,192,137 B ZIP 内）*

汇报稿 v0.1 · 2026-10-23 · 数字、截图与状态随合入更新；以随包证据与验收记录为准，不以本页为准。